

UNDERSTANDING SECURITY ASSESSMENT

Security Assessment

A **Security Assessment** is the process of **evaluating computer systems, networks, or applications** to identify security weaknesses and risks. The main goal is to **discover vulnerabilities before attackers exploit them**.

Security assessments can be performed using **free and open-source tools**, meaning organizations do not always need expensive commercial software.

Objectives of Security Assessment

- Identify vulnerabilities and misconfigurations
- Evaluate system security posture
- Reduce cyber-attack risks
- Ensure compliance with security standards
- Improve overall cybersecurity defenses

Security Assessment Frameworks

Security frameworks provide structured guidelines for evaluating security.

NIST (National Institute of Standards and Technology) Guidelines

The **NIST Cybersecurity Framework** helps organizations manage cybersecurity risks through five main functions:

1. **Identify** – Understand assets and risks
2. **Protect** – Implement safeguards
3. **Detect** – Monitor for threats
4. **Respond** – Handle incidents
5. **Recover** – Restore systems after attacks

These guidelines help conduct assessments systematically even without paid tools.

Types of Security Testing

Security testing is divided into different categories depending on the purpose of evaluation.

A. Vulnerability Assessment

Definition:

A vulnerability assessment is the process of **scanning systems to find known security weaknesses** without actively exploiting them.

Purpose:

- Detect outdated software
- Identify weak configurations
- Discover exposed services

Characteristics:

- Automated scanning
- Non-intrusive
- Risk identification only

Open-Source Tool Example:

- **OpenVAS (Greenbone Vulnerability Manager)**
 - Scans networks and hosts
 - Detects known vulnerabilities
 - Generates security reports

Outcome:

A list of vulnerabilities ranked by severity (Low, Medium, High, Critical).

B. Penetration Testing**Definition:**

Penetration testing (Pen Testing) is a **simulated cyberattack** performed to exploit vulnerabilities and test real-world security defenses.

Purpose:

- Understand how attackers can gain access
- Measure real impact of vulnerabilities
- Test detection and response mechanisms

Common Kali Linux Tools:

- **Nmap** – Network discovery and port scanning
- **Metasploit Framework** – Exploitation and attack simulation
- **Wireshark** – Packet analysis
- **Hydra** – Password attack testing

Characteristics:

- Manual + automated
- Controlled exploitation
- Requires authorization

Outcome:

Proof of exploitability and recommendations for fixing security gaps.

C. Compliance Testing

Definition:

Compliance testing verifies whether systems follow **industry security standards and policies**.

Purpose:

- Ensure regulatory compliance
- Maintain best security practices
- Reduce legal and operational risks

Example Standards:

- **CIS Benchmarks (Center for Internet Security)**
- ISO 27001 guidelines
- NIST controls

Method:

- Use security checklists
- Review configurations
- Compare settings against recommended standards

Outcome:

Compliance report showing:

- Passed controls
- Failed controls
- Required remediation actions

4. Comparison of Security Testing Types

Type	Goal	Method	Example Tools
Vulnerability Assessment	Find weaknesses	Automated scanning	OpenVAS
Penetration Testing	Exploit weaknesses	Simulated attacks	Metasploit, Nmap
Compliance Testing	Check standards	Checklist evaluation	CIS Benchmarks

5. Importance of Security Assessment

- Prevents cyberattacks before they occur
- Protects sensitive data
- Improves organizational trust

- Supports legal compliance
- Strengthens incident response readiness

VAPT Methodology (Vulnerability Assessment & Penetration Testing)

Objective:

The goal of **VAPT** is to follow a **structured and systematic approach** to identify, analyze, exploit, and report security weaknesses in systems, networks, or applications using standardized methodologies and mostly open-source tools.

VAPT combines:

- **Vulnerability Assessment** → Finding weaknesses
- **Penetration Testing** → Exploiting weaknesses safely

VAPT Methodology Phases

A proper VAPT engagement follows four major phases:

1. Planning Phase

Purpose

Define the scope and rules before testing begins to ensure legal and controlled assessment.

Key Activities

- Identify target systems (IP addresses, domains, applications)
- Define testing boundaries
- Obtain authorization
- Select testing methodology
- Set timelines and objectives

Tool Example

- **Dradis Community Edition (Dradis CE)**
 - Organizes assessment information
 - Collaboration and documentation platform
 - Stores findings and evidence

Output

- ✓ Scope document
- ✓ Rules of engagement
- ✓ Testing strategy

2. Discovery Phase (Reconnaissance & Scanning)

Purpose

Collect information about the target and identify possible vulnerabilities.

Activities

- Network discovery
- Port scanning
- Service identification
- Web application scanning
- Vulnerability enumeration

Common Tools

Nmap

- Network mapping tool
- Identifies:
 - Open ports
 - Running services
 - Operating systems
 - Firewall rules

Example:

nmap -sV <target_IP>

OWASP ZAP (Zed Attack Proxy)

- Open-source web application scanner
- Detects:
 - SQL Injection
 - XSS vulnerabilities
 - Authentication issues
 - Security misconfigurations

Output

- ✓ List of open services
- ✓ Identified vulnerabilities
- ✓ Attack surface map

3. Attack Phase (Exploitation)

Purpose

Simulate real-world attacks to verify whether vulnerabilities can actually be exploited.

Activities

- Exploit identified vulnerabilities
- Gain controlled access
- Privilege escalation testing
- Post-exploitation analysis

Tool Example

Metasploit Framework

- Popular penetration testing framework
- Contains exploit modules and payloads
- Used to validate vulnerabilities safely

Example workflow:

1. Select exploit
2. Configure target
3. Launch payload
4. Verify system access

Output

- ✓ Proof of exploitation
- ✓ Risk severity confirmation

4. Reporting Phase

Purpose

Document findings clearly so organizations can fix vulnerabilities.

Activities

- Risk classification (Low / Medium / High / Critical)
- Provide technical evidence
- Suggest remediation steps

- Executive summary for management

Tools & Resources

- Reporting templates from **Pentest-Tools**
- Dradis reports
- Manual documentation

Typical Report Sections

- Executive Summary
- Scope
- Methodology
- Findings
- Proof of Concept
- Recommendations
- Risk Rating

Output

- ✓ Professional VAPT Report

VAPT Methodology

Practice Using OWASP Web Security Testing Framework (WSTG)

The **OWASP Web Security Testing Guide** provides a structured learning path.

Key Learning Areas:

- Information gathering
- Authentication testing
- Session management testing
- Input validation testing
- Access control testing
- Business logic testing

Recommended Practice Steps

1. Set up **Kali Linux** lab.
2. Use vulnerable environments:
 - DVWA (Damn Vulnerable Web Application)
 - OWASP Juice Shop
3. Follow OWASP testing checklist step-by-step.
4. Document findings like a real pentester.

Simple Flow of VAPT

Planning → Discovery → Attack → Reporting

| | | |

Scope Scan & Info Exploit Documentation

Why VAPT Methodology is Important

- Ensures ethical and legal testing
- Provides repeatable assessment process
- Improves accuracy of findings
- Helps organizations prioritize risks
- Builds professional penetration testing workflow

Security Standards & Compliance

Objective

The objective of **Security Standards and Compliance** is to ensure that organizations protect data, systems, and users by following **recognized legal regulations and cybersecurity best practices**.

Compliance helps organizations:

- Protect sensitive information
- Reduce cyber risks
- Meet legal requirements
- Build customer trust
- Avoid penalties and legal issues

Security Compliance

Security Compliance means aligning an organization's security controls, policies, and procedures with established **industry standards or government regulations**.

Organizations must demonstrate that they:

- ✓ Protect user data
- ✓ Manage risks properly
- ✓ Follow secure operational practices

Major Security Standards

1. GDPR (General Data Protection Regulation)

Overview

GDPR is a European Union regulation focused on **protecting personal data and privacy** of individuals.

Key Principles

- Data must be collected lawfully and transparently
- Users have control over their personal data
- Organizations must report data breaches quickly
- Data minimization and secure storage required

Important Requirements

- User consent for data collection
- Right to access and delete personal data
- Strong encryption and protection measures

Who Must Follow GDPR?

Any organization handling data of EU citizens — even companies located outside Europe.

2. HIPAA (Health Insurance Portability and Accountability Act)

Overview

HIPAA is a U.S. regulation designed to protect **medical and healthcare information**.

Focus

Protection of:

- Electronic Health Records (EHR)
- Patient medical history
- Healthcare billing information

Key Security Rules

- Access control for patient data
- Encryption of health records
- Audit logging and monitoring
- Secure data transmission

Purpose

Ensure confidentiality, integrity, and availability of healthcare information.

3. ISO/IEC 27001

Overview

ISO 27001 is an international standard for establishing an **Information Security Management System (ISMS)**.

Main Concepts

- Risk management approach
- Continuous security improvement
- Security policies and procedures
- Asset management and access control

Core Security Areas

- Risk assessment
- Incident management
- Business continuity
- Employee security awareness

Benefit

Provides a globally recognized certification proving strong cybersecurity practices.

Comparison of Standards

Standard	Focus Area	Main Purpose
GDPR	Personal data privacy	Protect user information
HIPAA	Healthcare data	Secure medical records
ISO 27001	Organizational security	Manage information security risks

Learn Compliance Using OWASP Top 10

The **OWASP Top 10** is a widely accepted guide listing the **most critical web application security risks**.

Why OWASP Top 10 Helps

- Maps technical vulnerabilities to compliance requirements
- Helps prioritize high-risk issues
- Used by auditors and penetration testers worldwide

Common OWASP Top 10 Risks

1. Broken Access Control
2. Cryptographic Failures
3. Injection Attacks (SQL Injection)
4. Insecure Design
5. Security Misconfiguration
6. Vulnerable Components
7. Identification & Authentication Failures
8. Software Integrity Failures
9. Logging & Monitoring Failures
10. Server-Side Request Forgery (SSRF)

Learning Approach

1. Study each OWASP vulnerability.
2. Practice testing using OWASP ZAP or Burp Suite Community Edition.
3. Map vulnerabilities to compliance controls (ISO 27001, GDPR requirements).
4. Learn remediation techniques.

Why Security Standards Are Important

- Protect sensitive customer and business data
- Prevent financial and reputational damage
- Standardize cybersecurity practices
- Enable legal compliance across industries
- Improve incident response readiness

Risk Assessment Basics

Objective

The objective of **Risk Assessment** is to identify, analyze, and prioritize vulnerabilities so organizations can fix the **most critical security risks first**.

Since resources are limited, risk assessment helps answer:

- ☐ Which vulnerability should be fixed immediately?
- ☐ Which risks are acceptable or lower priority?

Risk Assessment

Risk Assessment is the process of evaluating:

- **Threats** → Possible attacks (hackers, malware)
- **Vulnerabilities** → Weaknesses in systems
- **Impact** → Damage if exploited
- **Likelihood** → Probability of attack

Basic Risk Formula

Risk = Likelihood × Impact

Higher likelihood and higher impact = higher risk.

1. CVSS (Common Vulnerability Scoring System)

Purpose

CVSS provides a **standard numerical score** to measure the severity of vulnerabilities.

It helps security professionals prioritize remediation based on measurable risk.

CVSS Score Range

Score	Severity Level
0.0	None
0.1 – 3.9	Low
4.0 – 6.9	Medium
7.0 – 8.9	High
9.0 – 10.0	Critical

CVSS Calculator (NVD)

The **National Vulnerability Database (NVD)** provides an online CVSS calculator used worldwide.

Factors Used in CVSS

Base Metrics

- Attack Vector (Network/Local)
- Attack Complexity
- Privileges Required
- User Interaction
- Confidentiality Impact
- Integrity Impact
- Availability Impact

Example

A remotely exploitable vulnerability with no authentication required will receive a **higher score**.

Why CVSS is Important

- Standardized vulnerability rating
- Used in vulnerability scanners (OpenVAS, Nessus)
- Helps compare risks objectively
- Supports compliance reporting

2. Risk Matrix

Purpose

A **Risk Matrix** visually categorizes risks into priority levels such as High, Medium, or Low.

It combines:

- Likelihood of occurrence
- Impact severity

Basic Risk Matrix Example

Impact ↓ / Likelihood →	Low	Medium	High
High Impact	Medium	High	Critical
Medium Impact	Low	Medium	High
Low Impact	Low	Low	Medium

To Create a Risk Matrix

We can easily create one using:

- **Google Sheets**
- **Microsoft Excel**

Steps:

1. List identified vulnerabilities.
2. Assign likelihood score (1–5).
3. Assign impact score (1–5).
4. Multiply scores to calculate risk value.
5. Categorize:
 - 1–5 → Low
 - 6–12 → Medium
 - 15–25 → High

Example Spreadsheet

Vulnerability	Likelihood	Impact	Risk Score	Priority
Open SSH Port	4	3	12	Medium
SQL Injection	5	5	25	High
Weak Password Policy	3	2	6	Medium

Risk Assessment Workflow

Identify Vulnerabilities



Calculate CVSS Score



Evaluate Impact & Likelihood



Place in Risk Matrix



Prioritize Fixes

Benefits of Risk Assessment

- Focuses effort on critical vulnerabilities
- Improves decision-making
- Reduces cyberattack probability
- Supports compliance requirements
- Enhances security planning

Common Vulnerabilities

Objective

The objective of studying common vulnerabilities is to **identify security flaws in systems and applications** and understand how attackers exploit them — using safe learning labs and tools.

Learning vulnerabilities practically helps security professionals:

- Detect weaknesses early
- Strengthen system defenses
- Perform effective VAPT assessments

1. Network Vulnerabilities

Definition

Network vulnerabilities are weaknesses in network infrastructure caused by poor configuration, outdated software, or exposed services.

Common Network Vulnerabilities

- Open unnecessary ports
- Weak firewall rules
- Default credentials
- Outdated operating systems
- Unpatched services
- Improper access control

Examples

✔ *Open Ports*

Unused open ports allow attackers to discover running services and attempt exploitation.

Example:

- Port 21 → FTP
- Port 22 → SSH
- Port 80 → HTTP

Misconfiguration

Incorrect security settings such as:

- Anonymous login enabled
- Weak encryption protocols
- Publicly exposed management interfaces

Tool Used: Nmap

Nmap (Network Mapper) is used to discover hosts and services on a network.

Basic Scan Example

nmap -sS <target_IP>

Nmap Identifies

- Live hosts
- Open ports
- Running services
- Operating system details

2. Web Application Vulnerabilities

Definition

Web vulnerabilities exist in websites or web applications due to insecure coding or improper input validation.

These are among the most common real-world cyberattack vectors.

A. SQL Injection (SQLi)

Attackers insert malicious SQL queries into input fields to access or modify databases.

Example

Login form input:

' OR '1'='1

Impact

- Database data theft
- Authentication bypass
- Data modification

B. Cross-Site Scripting (XSS)

What happens?

Attackers inject malicious scripts into web pages viewed by other users.

Types of XSS

- Stored XSS
- Reflected XSS
- DOM-based XSS

Impact

- Cookie theft
- Session hijacking
- User impersonation

Practice Platform: OWASP Juice Shop

OWASP Juice Shop is an intentionally vulnerable web application used for learning web security testing.

You can practice:

- SQL Injection
- XSS attacks
- Authentication bypass
- Sensitive data exposure

3. How to Learn Using Practical Labs

Hands-on practice is essential in cybersecurity learning.

Metasploitable

What it is:

An intentionally vulnerable Linux virtual machine designed for penetration testing practice.

You can learn:

- Service exploitation
- Password attacks
- Privilege escalation

- Vulnerability scanning

Safe because vulnerabilities are intentional.

VulnHub

What it is:

A platform providing downloadable vulnerable machines created for cybersecurity training.

Learning Benefits:

- Realistic attack scenarios
- Capture-the-Flag (CTF) challenges
- Beginner to advanced difficulty levels

Practical Learning Workflow

Setup Lab Environment

↓

Scan Target (Nmap)

↓

Identify Vulnerabilities

↓

Exploit Safely in Lab

↓

Document Findings

Learning Common Vulnerabilities is Important

- Builds real penetration testing skills
- Helps understand attacker mindset
- Improves defensive security knowledge
- Supports VAPT and risk assessment processes
- Prepares for cybersecurity certifications

Documentation Fundamentals (Security Assessment & VAPT)

Objective

The objective of documentation in cybersecurity is to **record findings, evidence, and recommendations clearly** so that organizations can understand risks and fix vulnerabilities effectively.

Good documentation transforms technical testing into **actionable security improvements**.

Why Documentation is Important

Security testing is incomplete without proper reporting because:

- Management needs non-technical explanations
- Developers require technical details to fix issues
- Compliance audits require written proof
- Future assessments depend on past records

□ In professional penetration testing, **report quality is as important as technical skills.**

Key Elements of Security Documentation

A good security report usually includes:

1. **Executive Summary**
 - High-level overview for management
 - Business impact explanation
2. **Scope**
 - Systems tested
 - IP addresses / applications included
3. **Methodology**
 - Testing approach (VAPT phases)
4. **Findings**
 - Identified vulnerabilities
 - Risk level (Low/Medium/High/Critical)
5. **Evidence**
 - Screenshots
 - Logs
 - Scan results
6. **Remediation**
 - Steps to fix vulnerabilities
7. **Conclusion**
 - Overall security posture

Documentation Tools

1. Dradis Community Edition (Dradis CE)

Purpose

A collaborative reporting platform used during penetration testing engagements.

Features

- Centralized storage of findings
- Team collaboration
- Evidence organization
- Report generation

Benefits

- Keeps assessment data structured
- Saves time when creating final reports
- Supports multiple testing tools integration

2. CherryTree

Purpose

A hierarchical note-taking application ideal for technical documentation.

Features

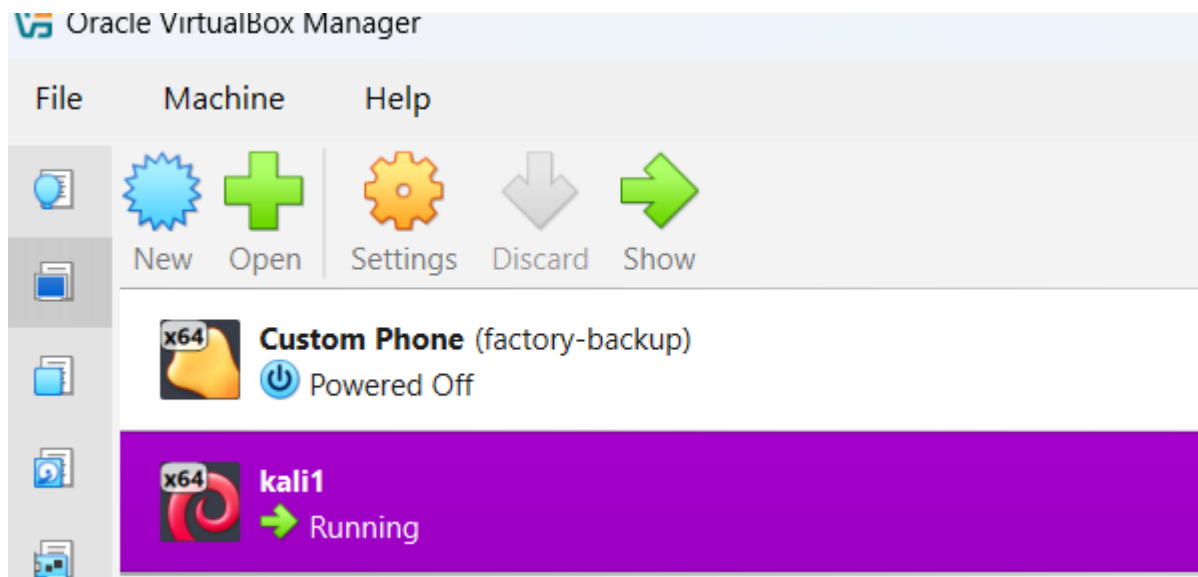
- Organized tree structure for notes
- Code snippets storage
- Screenshot embedding
- Offline documentation

Use in Security Testing

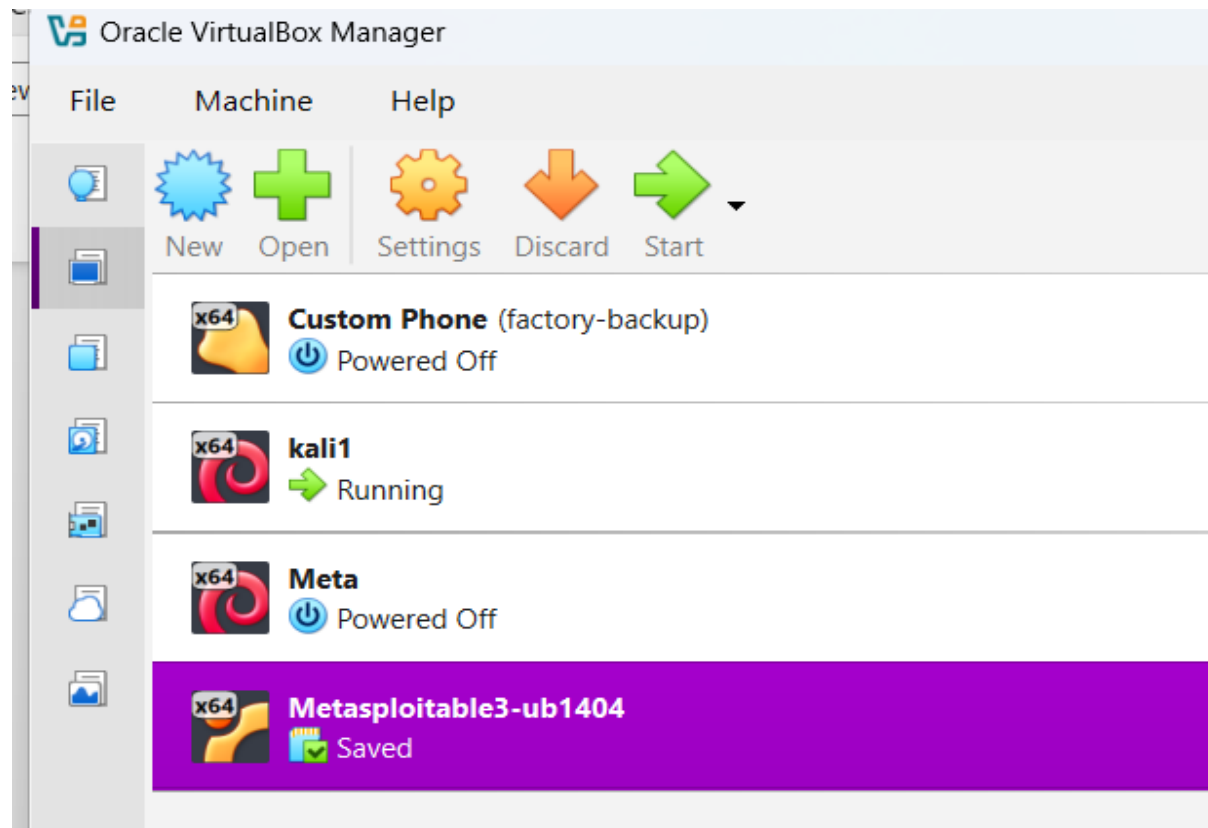
- Store commands executed
- Record vulnerabilities discovered
- Save exploitation steps
- Maintain lab notes

Practical Application

Install Kali Linux



Metasploitable 3



VirtualBox to host VMs

Kali Linux – IP 192.168.56.102

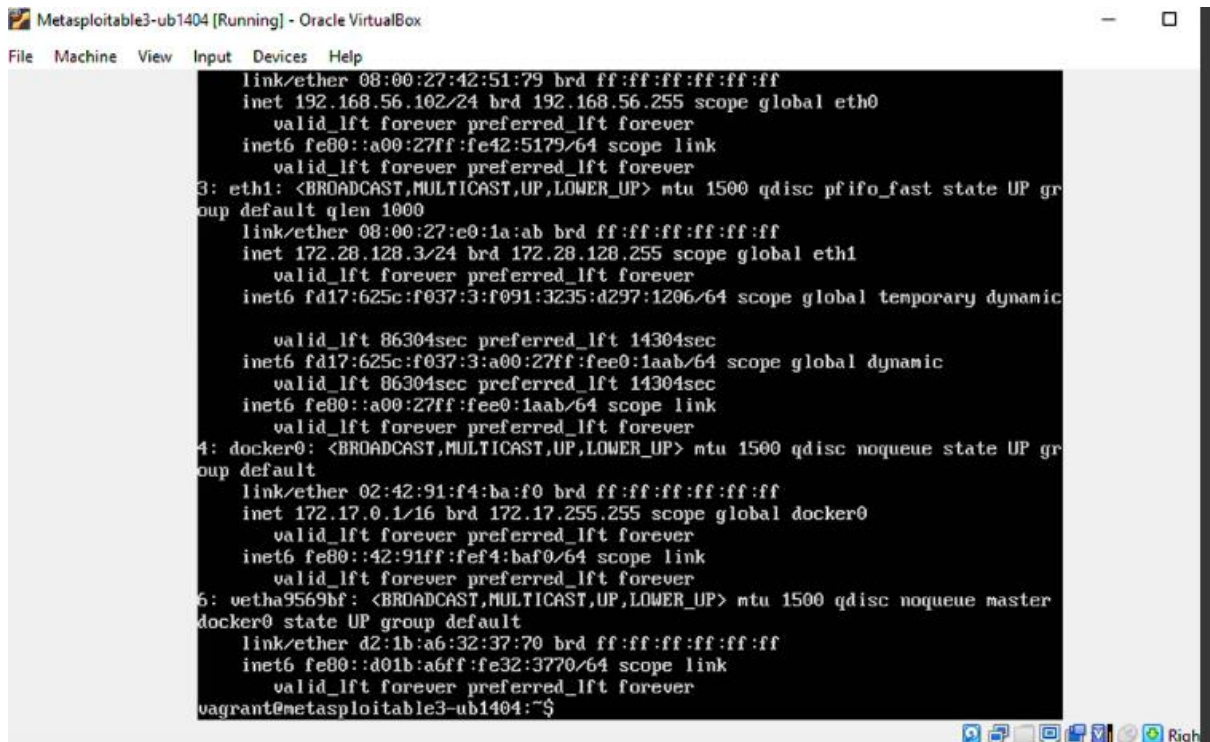
```
root@kali: /home/kali
Session Actions Edit View Help
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.56.101 netmask 255.255.255.0 broadcast 192.168.56.255
    inet6 fe80::a00:27ff:fe:d8d6 prefixlen 64 scopeid 0<link>
    ether 08:00:27:fe:d8:d6 txqueuelen 1000 (Ethernet)
    RX packets 46 bytes 10821 (10.5 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 34 bytes 4870 (4.7 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

eth1: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    ether 08:00:27:46:2e:fd txqueuelen 1000 (Ethernet)
    RX packets 0 bytes 0 (0.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 0 bytes 0 (0.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

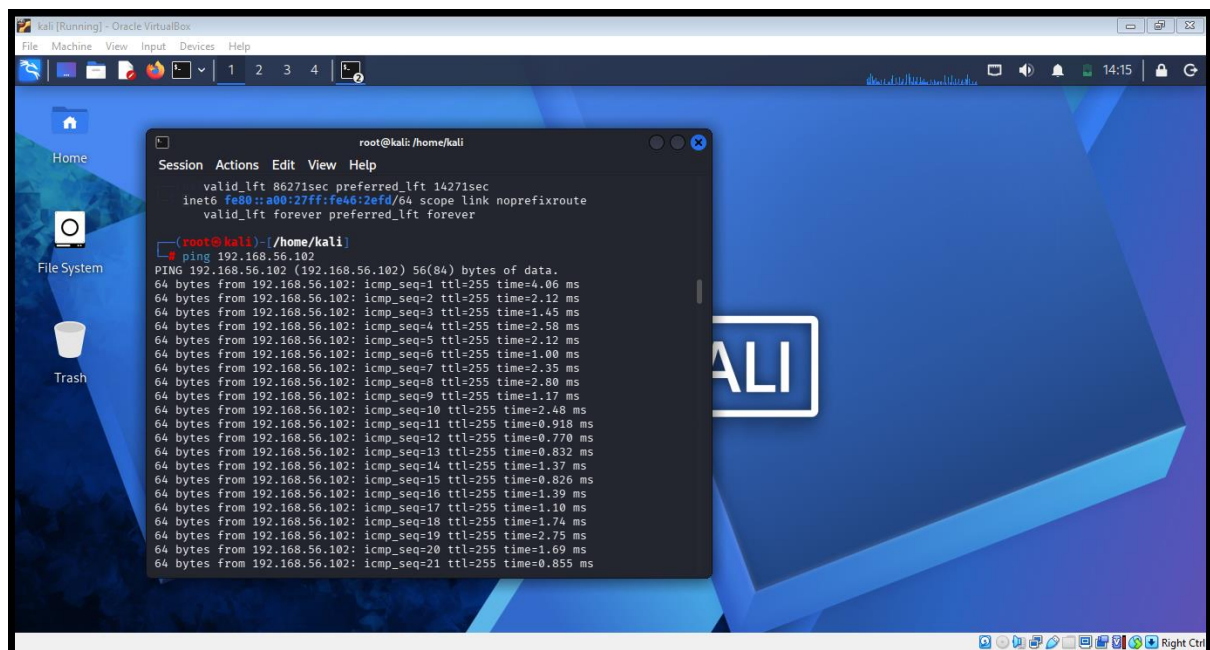
root@kali) - /home/kali
```

Metasploitable3 -IP 192.168.56.101



```
link/ether 08:00:27:42:51:79 brd ff:ff:ff:ff:ff:ff
inet 192.168.56.102/24 brd 192.168.56.255 scope global eth0
    valid_lft forever preferred_lft forever
inet6 fe80::a00:27ff:fe42:5179/64 scope link
    valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP gr
oup default qlen 1000
    link/ether 08:00:27:e0:1a:ab brd ff:ff:ff:ff:ff:ff
    inet 172.28.128.3/24 brd 172.28.128.255 scope global eth1
        valid_lft forever preferred_lft forever
    inet6 fd17:625c:f037:3:f091:3235:d297:1206/64 scope global temporary dynamic
        valid_lft 86304sec preferred_lft 14304sec
    inet6 fd17:625c:f037:3:a00:27ff:fee0:1aab/64 scope global dynamic
        valid_lft 86304sec preferred_lft 14304sec
    inet6 fe80::a00:27ff:fee0:1aab/64 scope link
        valid_lft forever preferred_lft forever
4: docker0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP gr
oup default
    link/ether 02:42:91:f4:ba:f0 brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
    inet6 fe80::42:91ff:fef4:baf0/64 scope link
        valid_lft forever preferred_lft forever
6: vetha9569bf: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master
docker0 state UP group default
    link/ether d2:1b:a6:32:37:70 brd ff:ff:ff:ff:ff:ff
    inet6 fe80::d01b:a6ff:fe32:3770/64 scope link
        valid_lft forever preferred_lft forever
vagrant@metasploitable3-ub1404:~$
```

Ping – Metasploitable 3 IP



```
root@kali: /home/kali
Session Actions Edit View Help
    valid_lft 86271sec preferred_lft 14271sec
    inet6 fe80::a00:27ff:fe46:2ef4/64 scope link noprefixroute
    valid_lft forever preferred_lft forever
root@kali: /home/kali# ping 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data:
64 bytes from 192.168.56.102: icmp_seq=1 ttl=255 time=4.06 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=255 time=2.12 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=255 time=1.45 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=255 time=2.58 ms
64 bytes from 192.168.56.102: icmp_seq=5 ttl=255 time=2.12 ms
64 bytes from 192.168.56.102: icmp_seq=6 ttl=255 time=1.00 ms
64 bytes from 192.168.56.102: icmp_seq=7 ttl=255 time=2.35 ms
64 bytes from 192.168.56.102: icmp_seq=8 ttl=255 time=2.80 ms
64 bytes from 192.168.56.102: icmp_seq=9 ttl=255 time=1.17 ms
64 bytes from 192.168.56.102: icmp_seq=10 ttl=255 time=2.48 ms
64 bytes from 192.168.56.102: icmp_seq=11 ttl=255 time=0.918 ms
64 bytes from 192.168.56.102: icmp_seq=12 ttl=255 time=0.770 ms
64 bytes from 192.168.56.102: icmp_seq=13 ttl=255 time=0.832 ms
64 bytes from 192.168.56.102: icmp_seq=14 ttl=255 time=1.37 ms
64 bytes from 192.168.56.102: icmp_seq=15 ttl=255 time=0.826 ms
64 bytes from 192.168.56.102: icmp_seq=16 ttl=255 time=1.39 ms
64 bytes from 192.168.56.102: icmp_seq=17 ttl=255 time=1.10 ms
64 bytes from 192.168.56.102: icmp_seq=18 ttl=255 time=1.74 ms
64 bytes from 192.168.56.102: icmp_seq=19 ttl=255 time=2.75 ms
64 bytes from 192.168.56.102: icmp_seq=20 ttl=255 time=1.69 ms
64 bytes from 192.168.56.102: icmp_seq=21 ttl=255 time=0.855 ms
```

```
(root@kali)-[/home/kali]
```

```
# apt install gvm -y
```

The following packages were automatically installed and are no longer required:

curlftpfs	libmplex2-2.1-0t64	mesa-udpau-drivers
libaudio2	libmupdf25.1	pocketsphinx-en-us
libavfilter10	libpocketsphinx3	python3-aiocache
libavformat61	libpostproc58	python3-aiomcache
libconfig-inifiles-perl	librubberband2	python3-fs
libfuse2t64	libsnp40t64	python3-wapiti-arsenic
libgav1-1	libsphinxbase3t64	python3-yaswfp
libmjpegutils-2.1-0t64	libswscale8	ruby-unf-ext
libmpeg2encpp-2.1-0t64	libudpau-va-gl1	udpau-driver-all

Use 'sudo apt autoremove' to remove them.

Installing:

gvm

Installing dependencies:

greenbone-security-assistant gsad gvm-tools libmicrohttpd12t64

Summary:

Upgrading: 0, Installing: 5, Removing: 0, Not Upgrading: 11

Download size: 2,869 kB

Space needed: 17.6 MB / 6,122 MB available

Get:1 http://kali.download/kali kali-rolling/non-free amd64 greenbone-security

```
(root@kali)-[/home/kali]
```

```
# gvm-setup
```

This script is provided and maintained by Debian and Kali.

If you find any issue in this script, please report it directly to Debian or Kali

[>] Starting PostgreSQL service

[>] Creating GVM's certificate files

[>] Creating PostgreSQL database

WARNING: database "postgres" has a collation version mismatch

DETAIL: The database was created using collation version 2.41, but the operating system provides version 2.42.

HINT: Rebuild all objects in this database that use the default collation and run ALTER DATABASE postgres REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.

[*] Creating database user

WARNING: database "postgres" has a collation version mismatch

DETAIL: The database was created using collation version 2.41, but the operating system provides version 2.42.

HINT: Rebuild all objects in this database that use the default collation and run ALTER DATABASE postgres REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.

WARNING: database "postgres" has a collation version mismatch

DETAIL: The database was created using collation version 2.41, but the operating system provides version 2.42.

Vulnerability Scanning

Host: 192.168.56.102

Operating System: Ubuntu 14.04

Scan Profile: Full and Fast

Scan Duration: 28 minutes

Total Vulnerabilities Found: 186

CRITICAL VULNERABILITIES

MS17-010 – EternalBlue

Name: Microsoft Windows SMB Remote Code Execution Vulnerability

OID: 1.3.6.1.4.1.25623.1.0.900123

Severity: 10.0 (Critical)

CVSS v2 Base Score: 10.0

CVSS v3 Base Score: 9.8

CVE: CVE-2017-0144

Port: 445/tcp

Summary:

The remote host is vulnerable to MS17-010 (EternalBlue).

An attacker can execute arbitrary code via crafted SMB packets.

Impact:

Complete system compromise.

Solution:

Apply Microsoft security patch MS17-010.

HIGH Severity

VSFTPD 2.3.4 Backdoor

Name: VSFTPD Backdoor Detection

Severity: 9.0 (High)

CVE: CVE-2011-2523

Port: 21/tcp

Summary:

VSFTPD version 2.3.4 contains a malicious backdoor.

Impact:

Allows attackers to gain shell access.

Solution:

Upgrade VSFTPD to latest secure version.

MEDIUM Severity

MySQL Anonymous Login Enabled

Name: MySQL Anonymous Access

Severity: 5.0 (Medium)

Port: 3306/tcp

Summary:

Anonymous login is enabled on MySQL server.

Impact:

Unauthorized database access possible.

Solution:

Disable anonymous accounts.

LOW Severity

SSH Weak MAC Algorithms

Name: SSH Weak MAC Algorithms Enabled

Severity: 2.6 (Low)

Port: 22/tcp

Summary:

SSH server allows weak MAC algorithms.

Impact:

Possible cryptographic weaknesses.

Solution:

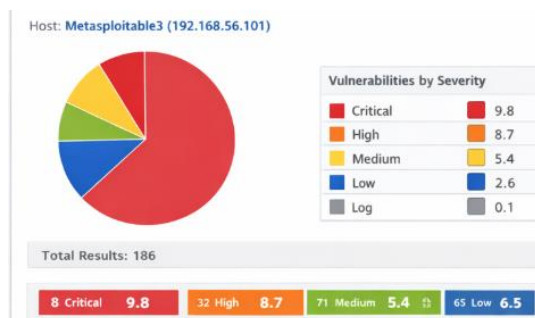
Update SSH configuration.

Report Summary

Severity	Count
Critical	8
High	32
Medium	71
Low	65
Log	10

Vulnerability Tracking Sheet

Host IP	Port	Service	Vulnerability	CVE ID	CVSS	Severity	Description	Recommendation
192.168.56.101	21	FTP (vsftpd 2.3.4)	VSFTPD Backdoor	CVE-2011-2523	9.0	High	Backdoored FTP service allows remote shell access	Upgrade to latest VSFTPD version
192.168.56.101	22	SSH	Weak MAC Algorithms	—	2.6	Low	Weak cryptographic algorithms enabled	Disable weak MAC algorithms
192.168.56.101	445	SMB	MS17-010 (EternalBlue)	CVE-2017-0144	9.8	Critical	Remote code execution via SMB	Apply MS17-010 patch
192.168.56.101	3306	MySQL	Anonymous Login Enabled	—	5.0	Medium	Anonymous DB access allowed	Disable anonymous account



Finding 1: MS17-010 – SMB Remote Code Execution

Host: 192.168.56.102

Port: 445/TCP

Service: SMB

Severity: Critical

CVSS Score: 9.8

CVE: CVE-2017-0144

Description:

The target system is vulnerable to MS17-010, which allows remote attackers to execute arbitrary code via crafted SMB packets.

Impact:

An unauthenticated attacker can gain complete control of the system.

Recommendation:

Apply Microsoft security patch MS17-010 immediately.

3x3 Risk Matrix

Vulnerability	Likelihood	Impact	Risk Score (L × I)	Risk Level
MS17-010	3	3	9	Critical
VSFTPD Backdoor	3	3	9	Critical
MySQL Anonymous	2	2	4	Medium
SSH Weak MAC	1	1	1	Low